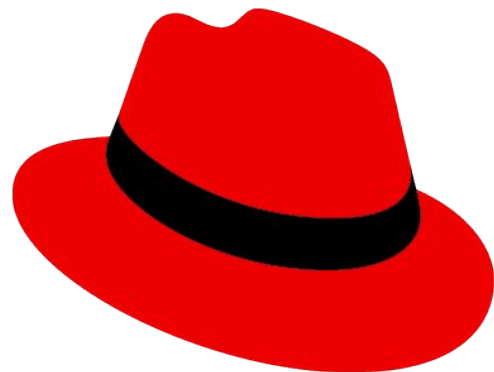




Red Hat

Telco Engineering / Workload team

NetGuard Endpoint Detection and Response Best Practices Results

Marcklyvens Morency
ANdrew VU



Plan

CONFIDENTIAL designator

- Best practice Intro
- Certsuite presentation
- Nokia NEDR certsuite results
- Failed test details analysys
- Recommendations

Red Hat Best Practices for Kubernetes document was originally created in 2020 by Verizon with assistance from Red Hat. Verizon's vision of an open collaborative process to create industry standards for cloud-native workloads led this document to be where it is today. Over many iterations, and based on lessons learned and feature improvements in the areas of security, lifecycle management, networking, and many other components, the document has matured into its current state.

More details [here](#).

The catalog for the Red Hat Best Practices Test Suite for Kubernetes contains a list of test cases aiming at testing best practices in various areas. Test suites are defined in 10 areas : platform-alteration, access-control, affiliated-certification, lifecycle, manageability, networking, observability, operator, preflight and performance.

Depending on the workload type, not all tests are required to pass to satisfy best practice requirements. The scenario section indicates which tests are mandatory or optional depending on the scenario. The following workload types / scenarios are defined: Telco, Non-Telco, Far-Edge, Extended.

More details [here](#).

Test cases summary

Total test cases: 119

Total suites: 10

Suite	Tests per suite
access-control	28
affiliated-certification	4
lifecycle	18
manageability	2
networking	12
observability	5
operator	12
performance	6
platform-alteration	14
preflight	18

NEDR test Results

What is NEDR

Nokia NetGuard Endpoint Detection and Response (EDR) agent is a lightweight, telecom-specialized endpoint detection and response tool that monitors, detects, and mitigates network threats in real time.

It is deployed as Daemonset to monitor security events in all nodes in a cluster.

Nokia plans to run it on HUB cluster hence we requested them to run the cert suite to better assist and provide our recommendation for Hub cluster safety

Component	Version
K8s	v1.31.6
OCP	4.18.2
CERTSUITE	V 5.5.17
CNF version	NEDR

Certsuite Config

targetNameSpaces:
- name: nedr-agent

Summary of results

CONFIDENTIAL designator

NEDR	
Failed	22
Passed	34
Skipped	45
TOTAL	102

SUITE	FAILED	PASSED	SKIPPED	ERROR
access-control	11	13	4	0
affiliated-certification	0	0	3	1
lifecycle	6	4	9	0
manageability	0	1	1	0
networking	3	3	5	0
observability	1	2	2	0
operator	0	0	12	0
performance	0	2	5	0
platform-alteration	1	9	4	0
TOTAL	22	34	45	1

Failed Test per Category details

CONFIDENTIAL designator

- Access control :

Cluster Role Binding , IPC Lock , NS resource Quota , security context privilege.
Pod-host-ipc. Pod-host-network, pod-host-path , pod-host-pid , ssh-daemons,
one-process-per-container , pod-automount-service-account-token

- Lifecycle:

Container Prestop, pod-owner-type, pod-scheduling, pod-tolerations-bypass,
startup Probe , readiness probe ,

- Network

Network Policy deny all , undeclaredContainer ports usage , reserved-port-usage

- Observability :
termination Policy
- Platform
is Redhat release

Failed test case details

CONFIDENTIAL designator

Test ID	Category	Impact	Remediation	Priority
access-control-pod-host-pid	Access control	Host PID access allows containers to see and interact with all host processes, creating opportunities for privilege escalation and information disclosure.	Set the spec.HostPid parameter to false in the pod configuration. Workloads should avoid accessing host resources - spec.HostPid should be false.	1
access-control-pod-host-path	Access control	Host path mounts can expose sensitive host files to containers, enable container escape attacks, and compromise host system integrity.	Set the spec.HostPath parameter to false in the pod configuration. Workloads should avoid accessing host resources - spec.HostPath should be false.	1
access-control-pod-host-network	Access control	Host network access removes network isolation, exposes containers to host network interfaces, and can compromise cluster networking security.	Set the spec.HostNetwork parameter to false in the pod configuration. Workloads should avoid accessing host resources - spec.HostNetwork should be false.	1
access-control-pod-host-ipc	Access control	Host IPC access allows containers to communicate with host processes, potentially exposing sensitive information and enabling privilege escalation.	Set the spec.HostIpc parameter to false in the pod configuration. Workloads should avoid accessing host resources - spec.HostIpc should be false.	1

Test ID	Category	Impact	Remediation	Priority
access-control-namespace-resource-quota	Access control	Without resource quotas, workloads can consume excessive cluster resources, causing performance issues and potential denial of service for other applications.	Apply a ResourceQuota to the namespace your workload is running in. The workload's namespace should have resource quota defined.	1
access-control-security-context	Access control	Incorrect security context configurations can weaken container isolation, enable privilege escalation, and create exploitable attack vectors.	Remove some capabilities into the SCC	1
access-control-ssh-daemons	Access control	SSH daemons in containers create additional attack surfaces, violate immutable infrastructure principles, and can be exploited for unauthorized access.	Ensure that no SSH daemons are running inside a pod. Pods should not run as SSH Daemons (replicaset or statefulset only).	2
access-control-security-context-non-root-user-id-check	Access control	Running containers as root increases the blast radius of security vulnerabilities and can lead to full host compromise if containers are breached.	Set the securityContext.runAsNonRoot field to true either at pod or container level. Alternatively, set a non-zero value to securityContext.runAsUser field either at pod or container level.	0

Test ID	Category	Impact	Remediation	Priority
				CONFIDENTIAL designator
access-control-cluster-role-bindings	Access control	Cluster-wide role bindings grant excessive privileges that can be exploited for lateral movement and privilege escalation across the entire cluster.	In most cases, Pod's should not have ClusterRoleBindings. The suggested remediation is to remove the need for ClusterRoleBindings, if possible. Cluster roles and cluster role bindings discouraged unless absolutely needed by the workload (often reserved for cluster admin only).	2
access-control-pod-automount-service-account-token	Access control	Auto-mounted service account tokens expose Kubernetes API credentials to application code, creating potential attack vectors if applications are compromised.	Check that pod has automountServiceAccountToken set to false or pod is attached to service account which has automountServiceAccountToken set to false, unless the pod needs access to the kubernetes API server. Pods which do not need API access should set automountServiceAccountToken to false in pod spec.	1
access-control-one-process-per-container	Access control	Multiple processes per container complicate monitoring, debugging, and security assessment, and can lead to zombie processes and resource leaks.	Launch only one process per container. Should adhere to 1 process per container best practice wherever possible.	4

Test ID	Category	Impact	Remediation	Priority	CONFIDENTIAL designator
lifecycle-container-pres top	lifecycle	Missing PreStop hooks can cause ungraceful shutdowns, data loss, and connection drops during container termination.	The preStop can be used to gracefully stop the container and clean resources (e.g., DB connection).	3	
lifecycle-pod-owner-type	lifecycle	Naked pods and DaemonSets lack proper lifecycle management, making updates, scaling, and recovery operations difficult or impossible.	Deploy the workload using ReplicaSet/StatefulSet.	3	
lifecycle-pod-scheduling	Life cycle	Node selectors can create scheduling constraints that reduce cluster flexibility and cause deployment failures when nodes are unavailable.	In most cases, Pod's should not specify their host Nodes through nodeSelector or nodeAffinity.	2	
lifecycle-pod-toleration -bypass	Life cycle	Modified tolerations can allow pods to be scheduled on inappropriate nodes, violating scheduling policies and causing performance issues.	Do not allow pods to bypass the NoExecute, PreferNoSchedule, or NoSchedule tolerations that are default applied by Kubernetes.	2	
lifecycle-startup-probe	Lifecycle	Missing startup probes can cause slow-starting applications to be killed prematurely, preventing successful application startup.	Add a startup probe to deployed containers	2	



Test ID	Category	Impact	Remediation	
networking-ocp-reserved-ports-usage	network	Using OpenShift-reserved ports can cause critical platform services to fail, potentially destabilizing the entire cluster.	Ensure that workload's apps do not listen on ports that are reserved by OpenShift. The following ports are reserved by OpenShift and must NOT be used by any application: 22623, 22624.	1
networking-network-policy-deny-all	network	Without default deny-all network policies, workloads are exposed to lateral movement attacks and unauthorized network access, compromising security posture and potentially enabling data breaches.	Ensure that a NetworkPolicy with a default deny-all is applied. After the default is applied, apply a network policy to allow the traffic your application requires.	1
networking-undeclared-container-ports-usage	network	Undeclared ports can be blocked by security policies, causing unexpected connectivity issues and making troubleshooting difficult.	Ensure the workload's apps do not listen on undeclared containers' ports.	1

CONFIDENTIAL designator

Test ID	Category	Impact	Remediation	
platform-alteration-isredhat-release	platform-alteration	Non-Red Hat base images may lack security updates, enterprise support, and compliance certifications required for production use.	Build a new container image that is based on UBI (Red Hat Universal Base Image).	4
observability-termination-policy	observability	Incorrect termination message policies can prevent proper error reporting and make failure diagnosis difficult.	Ensure containers are all using FallbackToLogsOnError in terminationMessagePolicy	2

CONFIDENTIAL designator

Legend : priority 0 is highest and 4 lowest.

Hub Cluster Security – Risks and Considerations

- Hub cluster manages several Workload clusters
- Its security posture, resource availability, and operational integrity are critical to the entire fleet
- Any disruption or compromise at the Hub level could impact all managed clusters
- Hub life cycle management is vital for the entire workload clusters
- Securing and properly resourcing the Hub cluster is essential to maintaining operational integrity across all downstream environments

Recommendations

Nokia needs to fix all test cases with Priority 0 and 1 for Redhat to support NEDR running on Hub cluster.

Thank you

Red Hat is the world's leading provider of enterprise open source software solutions. Award-winning support, training, and consulting services make Red Hat a trusted adviser to the Fortune 500.

 [linkedin.com/company/red-hat](https://www.linkedin.com/company/red-hat)

 [facebook.com/redhatinc](https://www.facebook.com/redhatinc)

 [youtube.com/user/RedHatVideos](https://www.youtube.com/user/RedHatVideos)

 twitter.com/RedHat

